

ISE 331: Fundamentals of Computer Security

Practice Problems for Lectures 13 to 17 (Network Security)

Directions: Below is a set of exercises and problems you should do for practice. Answering this set of questions should be just one part of your preparation for quizzes and exams. In addition to solving these problems you should:

- Review the lecture notes.
- Review your homework assignments.
- Form a study group and test each other on the material.

Note: The solution is provided on the last page. It is strongly recommended that you work on the questions first before going to the solution.

Part I. Multiple Choice

1. For standard DNS, which attack is the most difficult to perform?
 - A. Fake DNS responses on local network
 - B. Use malware to add entries in /etc/hosts
 - C. Poison cache for NS record in local DNS server
 - D. Take over generic top-level domain DNS server
2. Which is incorrect regarding Query ID in a DNS packet?
 - A. It was originally a functionality mechanism, later became an implicit security mechanism
 - B. A DNS response that contains a non-matching Query ID will be dropped
 - C. An attacker cannot forge a valid DNS response if he does not know the original Query ID
 - D. It is a 16-bit number located at the beginning of a DNS packet
3. An on-path attacker wants to fake DNS response from the local DNS server to the client. Which might be an obstacle?
 - A. The attacker cannot observe the traffic between the local DNS server and the Root Nameservers
 - B. The attacker cannot guess the correct Query ID in the request sent by the client
 - C. The attacker cannot match the destination and source port numbers
 - D. The attacker cannot make the fake response arrive at the client soon enough
4. You queried local DNS server for the A record of www.example.com. Assume the relevant information is already in cache, which is correct?
 - A. The local DNS server will still communicate with the nameserver of example.com for confirmation
 - B. The local DNS server will send you a response containing the IPv4 address of www.example.com
 - C. An attacker within local network cannot fake the response from the local DNS server to you
 - D. An attacker can poison the cache of the local DNS server if his response arrives before your query
5. Which description best fits an Autonomous System (AS) in the context of Internet routing and Border Gateway Protocol (BGP)?
 - A. A type of server that handles BGP requests on the Internet.
 - B. A single router that handles all Internet traffic for a specific country or region.
 - C. An administrative entity that manages a collection of IP prefixes on the Internet.
 - D. A security protocol used for data encryption and authentication on the Internet.

6. In standard BGP, an attacker announces a fake route to attract Internet traffic. Which of the following is incorrect?
- A. The attacker can drop all traffic and cause blackholing.
 - B. The attacker can eavesdrop on traffic passing through the fake route.
 - C. The attacker can modify passing certificates without being detected.
 - D. The attacker can drop packets selectively and make the connection instable.
7. To prevent or stop Denial of Service (DoS) attack as the victim, ____ is not a valid option.
- A. Perform ingress filtering near the victim
 - B. Stop responding to requests sent by all users
 - C. Use anti-DoS protection provided by companies like Cloudflare
 - D. Acquire more resources to deal with the attacks
8. To delay the calculus exam, the attacker used his botnet of 600,000 IP cameras all over the world to send requests to the university's website at the same time. This is a(n) ____.
- A. Amplified Denial of Service Attack
 - B. Application-layer Denial of Service Attack
 - C. Distributed Denial of Service Attack
 - D. Reflected Denial of Service Attack
9. Which is NOT a feature of worms in computer security?
- A. Self-evolution B. Self-propagation C. Self-replication D. Can carry payload
10. In a network where most internal hosts are behind a firewall that blocks incoming traffic, which targeting strategy would likely be the best for a worm trying to spread internally?
- A. Local subnet scanning
 - B. Hit-list scanning
 - C. Pseudorandom scanning
 - D. Random scanning
11. A Network-based IDS (NIDS) performs TCP stream reassembly before applying signature-based detection. Why is this step necessary?
- A. It can reduce data size by deleting encapsulation headers.
 - B. It can decrypt the message and prepare plaintext for signature matching.
 - C. It can remove separators to combine segmented messages.
 - D. It can convert other protocols' traffic to TCP for content analysis.
12. An organization deploys an anomaly-based IDS in an environment where user behavior changes frequently. What is the most likely operational challenge?
- A. The IDS has difficulty detecting a long list of attack signatures.
 - B. The IDS suffers from a high rate of false positives.
 - C. The IDS needs a great amount of computing power to analyze anomalies.
 - D. The IDS cannot predict frequently changing user behaviors.
13. Which firewall policy matches the Least Privilege Principle?
- A. Default-allow: Drop only known malicious ports and protocols.
 - B. Default-deny: Drop all traffic except for specifically accepted ones.
 - C. Dynamic-allow: Open ports automatically when a host requests them.
 - D. Egress-only: Only allow traffic leaving the network.
14. What is the primary advantage of a stateful firewall over a stateless firewall?
- A. It can combine segmented messages for better situational awareness.
 - B. It takes significantly less computing power to achieve similar results.
 - C. It can track the state of a connection to allow for more detailed policies.
 - D. It does not need to track a connection on different ports.

15. A stateless firewall is configured to block incoming connections by dropping packets with the SYN flag, while allowing packets with the ACK bit set. What is a security problem of this approach?
- A. It allows an attacker to determine what type of firewall is used.
 - B. It prevents legitimate users from starting outbound connections.
 - C. It cannot deal with stateless protocols such as UDP.
 - D. It requires the firewall to create and update a connection table.

Part II. True or False

1. Standard DNS was designed without encryption or authentication.
2. By cryptographically signing DNS responses, DNSSEC solved the problem of DNS-based Distributed Denial of Service (DDoS) attacks.
3. When the local DNS server has no cache for your request, your computer will start querying the root nameservers.
4. A DNS query sent to the local DNS server with a Query ID of 16383 will be responded by a Query ID of 16384.
5. Border Gateway Protocol (BGP) is responsible for both intra-AS and inter-AS communications.
6. Standard BGP has no encryption or authentication, making it vulnerable to prefix hijacking.
7. To perform prefix hijacking in BGP, both announcing a more specific path and announcing a shorter path will work.
8. Denial of Service (DoS) attacks breaks the availability aspect of the CIA triad.
9. If a computer is infected by a rootkit, the rootkit can be discovered by running full-disk scan in the operating system.
10. Known worms can be detected by recognizing byte patterns in packets of incoming data.
11. In general, IDS using misuse detection has a high tendency to miss known attacks.
12. An IDS with 100% precision ($TP/(TP+FP) = 1$) is a prefect IDS.
13. A "Default-deny" policy is generally more secure but can cause issues for legit users.
14. In general, all networked devices have some type of firewall nowadays.
15. The Zero Trust model assumes that once a device is inside the corporate network, it can be trusted and does not require continuous validation.

Part III. Short Answer

1. An attacker writes a script that generates a fake DNS response packet according to the intercepted DNS query packet sent by the victim. Assume the DNS query packet has the following fields, what should be the values for those fields in the fake DNS response packet?
Source: 1.3.5.7 Destination: 8.6.4.2 Source port: 6789 Destination port: 53
Query ID: 12345 Query/Response bit: 0
2. A local DNS server queried the nameserver of example.com for the IPv4 address of www.example.com. An attacker successfully faked the response and set the IP address of www.example.com to be 1.2.3.4. Answer the questions below.
 - 1) Can the attacker also set the IP address of the nameserver of example.com? Why or why not?
 - 2) Can the attacker also set the IP address of the nameserver of amazon.com? Why or why not?
3. In the Kaminsky Attack, the attacker queries the local DNS server for IP addresses of non-existent websites. Why does the attacker need to do this? What if the attacker just queries the local DNS server for IP addresses of existing websites instead?
4. In the Kaminsky Attack, assume that the attacker failed to fake a correct response in time, and the response from the real nameserver reached the local DNS server that is being attacked. Does the attacker need to wait until the cache expires to perform another attack? Why or why not?
5. List one similarity and one difference between the Public Key Infrastructure (PKI) used in TLS and the Resource Public Key Infrastructure (RPKI) used in BGP.
6. BGPsec requires each Autonomous System (AS) digitally signs its portion of the AS path when forwarding a route to a neighbor. Compared with TLS, is it easier or more difficult to perform incremental deployment? Why?
7. In a reflected DoS attack using DNS amplification, the victim's IP address is 1.2.3.4, the attacker's IP address is 5.6.7.8, and the DNS server's IP address is 10.3.3.1. Assume that the victim and the attacker are in different Autonomous Systems and have different Internet Service Providers (ISPs). Answer the following questions:
 - 1) The attacker begins the attack by sending a DNS request to the DNS server. How should the attacker fill in the source and the destination IP addresses?
 - 2) Briefly describe what happened in the attack.
 - 3) How can the attacker's ISP prevent such attacks?
8. Describe how to use "background radiation" to measure worm activity.
9. Describe the advantages and disadvantages of signature-based IDS compared to anomaly-based IDS. List one each.
10. Come up with a simple misuse detection method to detect if someone is leaking patient information in a hospital.
11. What is the most fundamental difference between Stateless and Stateful firewalls?
12. One of the properties/rules of a classical firewall is "Trust inside nodes, do not trust outside nodes.". What problem may arise if we strictly follow this rule? Provide an example.

Part I Solution:
1-5 DCDBC 6-10 CBCAA
11-15 CBBCA

Part II Solution:
1-5 TFFFF 6-10 TTTFT
11-15 FFTTF

Part III Solution:

1. Source: 8.6.4.2 Destination: 1.3.5.7 Source port: 53 Destination port: 6789
Query ID: 12345 Query/Response bit: 1
(Swap source with destination, swap source port with destination port, query ID stays the same, QR bit set to 0 for response)
2. 1) Yes, an authoritative nameserver for example.com is allowed to provide records for anything within that domain, including its own nameserver.
2) No, The Bailiwick check prevents a server from providing records for domains it doesn't own. For example, the nameserver of example.com cannot provide records for amazon.com.
3. The attacker queries non-existent subdomains to bypass the cache. Since these random subdomains are not stored, the local DNS server is forced to query the authoritative nameserver, creating a race condition that the attacker can exploit.
If the attacker sends requests for existing websites, there is a chance that the answer is already in the cache of the local DNS server. In that case, the local DNS server can just reply to the attacker directly, and there will be no chance to fake a response because the local DNS server will not communicate with the nameserver.
4. The attacker does not need to wait for the cache to expire, because he can always send another request for a different non-existent website under the same parent domain. Since that new subdomain isn't cached, a new race begins immediately, and the attacker again have the opportunity to fake a response.
5. Similarities: 1. Both are hierarchal structures that issue certificates for authentication.
 2. Both utilize a chain of trust, with the top level entities in the system being the trust anchor.
 (Other reasonable answers are fine)
Differences: 1. PKI (TLS) verifies that a website owns a public key; RPKI (BGP) verifies that an organization owns a specific IP address block and/or an AS number.
 2. PKI prevents MitM attacks in TLS, while RPKI prevents prefix hijacking in BGP.
 (Other reasonable answers are fine)

6. It is more difficult for BGPsec to deploy incrementally. BGPsec requires every AS in a path to sign the update. If one link fails, the entire chain of trust is broken. In contrast, TLS only requires the two endpoints to support it, making incremental deployment much easier.
7. 1) Source: 1.2.3.4 (IP spoofing, fill in the victim's address) Destination: 10.3.3.1
2) The attacker sends a flood of DNS query packets to the DNS server, with source filled in with the victim's IP address. The server responds with a flood of DNS response packets sent to the victim. The size of the response packets is generally greater than the size of the query packets, amplifying the attack. If the victim is overwhelmed by the flood of responses, the DoS attack becomes successful.
3) The attacker's ISP can perform ingress filtering (BCP 38), dropping all packets with a source IP that does belong to its network.
8. Monitor traffic to "unused" IP address spaces. Since legitimate users don't visit these addresses, any traffic spikes detected there usually represent the indiscriminate scanning of worms, and can be used to measure worm activity.
9. Advantages: 1. Has high precision detecting known attacks, with minimal false positives.
2. Does not need training; only need to check against a list of signatures
(Other reasonable answers are fine)
Disadv: 1. Can only detect known attacks. In contrast, anomaly-based detection can detect unknown attacks.
2. Needs constant updates for the list of signatures.
(Other reasonable answers are fine)
10. Use bait/trap tactic (honeypot). Create a dummy patient's record, with the name of a celebrity and some nasty symptoms. Any access or mention of this record outside the hospital triggers an immediate alert.
11. Stateless firewalls make decisions by considering each packet in isolation, while stateful firewalls make decisions by considering each packet in the context of the connection/session it belongs to.
12. If we strictly follow this rule, any compromised internal device will still be trusted, and can easily leak confidential information to outside nodes. For example, if an employee's laptop is infected with malware, it may send company secrets to the outside nodes, and the firewall policies will not stop it because all internal nodes are to be trusted.